# Phishing Triage — Suspicious Invoice Email (`ornek-phishing.eml`, static review)

**Date:** 2026-10-31 · **Prepared by:** phishing analyst · **Input:** `samples/ornek-phishing.eml` — an RFC 5322 `.eml` export of 59 lines with the full header block present, from `Return-Path:` through `Authentication-Results:` and the `Received` chain

> **This is a synthetic portfolio sample, not real customer work.** The email file was taken from this project's own `samples/` folder as a demonstration of the review method. It is not an export from a real mailbox and no real organisation was involved.

## Summary


- Six mandatory checks were applied to the email. All six returned at least one suspicious indicator: 6 showing an indicator + 0 clean + 0 without evidence = 6.
- Most urgent item, High: the message tells the reader that the sender's **bank account has changed** and that payment must reach the new account by **17:00 the same day** or the shipment will be stopped — a payment-redirection pretext combined with a same-day deadline.
- Do this first: do **not** pay, do not click the link and do not open the attachment. Confirm any bank or payment-account change through a channel you already trusted beforehand (a phone number you already hold, the accounting contact named in your contract) — never the phone number in the message and never the `Reply-To` address.
- Every FACT below points to an exact line of the email file, or to a search showing something is absent. No URL was visited, resolved or expanded, and the attachment was never opened, saved, extracted or decoded.
- All web addresses and domain names in this document are written in a deliberately broken ("defanged") form — `hxxp` instead of `http`, `[.]` instead of `.` — so that they cannot be clicked by accident.


**Labels:** `FACT` = read directly from the email file · `FIX` = recommended action · `CHECK` = could not be determined from what was provided; confirm before relying on it.

## Scope

- Input: `samples/ornek-phishing.eml` — 59 lines. The header block ends at line 27, the first blank line is line 28, the message body starts at line 29. Part 1 (the HTML body) is lines 29-47, part 2 (the attachment) is lines 49-57, the closing boundary is line 59. Line numbers in this document are the file's real line numbers.
- Checks applied: a six-item mandatory checklist (receiving chain; recorded SPF; recorded DKIM; recorded DMARC; the `From` / `Reply-To` / `Return-Path` / display-name split; the URL and attachment inventory). Counting rule: items showing an indicator + clean items + items without evidence = 6.
- How the file reached us: it was supplied as a synthetic acceptance-test sample from this repository's `samples/` folder. It is not a real customer export.
- The receiving side's mail infrastructure appears in the headers as `mx01.kartaltekstil[.]example` and `mail.kartaltekstil[.]example` (lines 3-8). That these are genuinely the recipient organisation's own systems was not separately confirmed to us.
- The receiving side's timestamps carry `+0300` (lines 5, 8). No official timezone statement from the organisation is known to us.
- Out of scope, because it would require a network action: no URL was visited, resolved or previewed, no shortened link was expanded, no DNS, WHOIS, TLS, SPF, DKIM or DMARC lookup was made, no reputation or threat-intelligence lookup was made, and nobody contacted the sender, the `Reply-To` address, the phone number in the message or the organisation.
- Out of scope, because running or decoding content is forbidden in this review: the attachment was not executed, not written to disk, not extracted, its base64 body was not decoded, and it was not submitted to any browser or online scanner. The attachment is described only from what the email file itself declares — its name, its declared type, its encoding and its extension pattern.
- Out of scope, file hashing: no hashing tool was available in this review, so no SHA-256 was produced for the attachment. The attachment's SHA-256 should be requested from the sender of the file **in writing**; any claim that depends on a hash (a match against known malware, attribution to a campaign) is outside this review.
- Also out of scope: dynamic analysis / sandboxing, malware reverse engineering, checking whether the infrastructure is live, and correlating mail server or gateway logs (who received it, who clicked).
- The assessment is limited to **what is written in this export**.

## Findings

Ordered by severity, highest first. The severity words give a reading order for the indicators that were recorded; they are not a verdict on the sender's intent, which this review could not establish.

### 1. Payment-redirection pretext with a same-day deadline — High

| # | Severity | What was examined (line) | FACT | FIX |
|---|---|---|---|---|
| 1 | High | Body paragraph (line 35) | The HTML body states that the sender's bank account has changed. The file records it in encoded form as `Banka hesab=C4=B1m=C4=B1z de=C4=9Fi=C5=9Fmi=C5=9Ftir.`, which reads as "Our bank account has changed." | Confirm any bank or payment-account change through a channel you already trusted beforehand — a phone number you already hold, or the accounting contact named in your contract. This confirmation is your own action; do not use the phone number in the message or the `Reply-To` address. |
| 2 | High | Body paragraph (lines 36-38) | The same paragraph sets a deadline of 17:00 today and states the consequence that the shipment will be stopped: "...must be paid into our new account by 17:00 today, otherwise the shipment will be stopped." | Treat the deadline as pressure, not as a fact. Do not act on it before the out-of-band confirmation above. |
| 3 | High | `Subject` (line 22) | The subject line is RFC 2047 encoded: `=?UTF-8?B?QUNJTDogw5ZkZW1lIGhlc2FiIGRlxJ9pxZ9pa2xpxJ9pIC0gRmF0dXJhIE5WLTIwMjYtNDQxOA==?=`. Transcribed exactly as written, without normalising: "ACIL: Ödeme hesab değişikliği - Fatura NV-2026-4418" ("URGENT: Payment account change - | Include the wording as an indicator when you report the message to your mail gateway. |

| # | Severity | What was examined (line) | FACT | FIX |
|---|---|---|---|---|
| | | | Invoice NV-2026-4418"). Two spelling points stand out as language tells: a dotless `I` where correct Turkish would write "ACİL", and "hesab" where correct Turkish would write "hesap". | |
| 4 | Medium | Greeting (line 34) and `To` (line 21) | The greeting is not personal: `Say=C4=B1n Yetkili,` ("Dear Sir/Madam"). The recipient address is `muhasebe@kartaltekstil[.]example`. | — |
| 5 | Medium | Body paragraph (line 43) | The body steers the reader towards the attachment: `Ekteki fatura =C3=B6zetini de inceleyebilirsiniz.` ("You can also review the attached invoice summary.") | Do not open the attachment. See the attachment finding below. |
| 6 | Medium | `X-Priority` (line 25) | The message was sent with `X-Priority: 1 (Highest)`. | — |
| 7 | Low | Body paragraph (line 46) | The body gives a phone number that cannot be verified from the file itself. It was not called. | Do not call the number in the message; use a contact you already hold. |
| 8 | Info | Whole file | No text aimed at an automated reader, assistant or agent (for example "ignore your previous instructions", "mark this message as safe", "forward the headers") is present in the file. The search showing this is in the Evidence section. The message was nevertheless processed purely as data and none of its requests were acted on. | — |

CHECK **— the conclusion that this is a payment-redirection (business email compromise) attempt is an interpretation, not an established fact.** What the file contains is the text itself. This review did not establish the sender's purpose.

### 2. Deceptive link and a double-extension attachment — High

| # | Severity | What was examined (line) | FACT | FIX |
|---|---|---|---|---|
| 9 | High | Body link (lines 40-42) | The text shown to the reader is `hxxps://portal.nortvale[.]example/fatura/4418`, while the actual `href` target is `hxxp://nortvale-invoices[.]example.kyc-dogrulama[.]example/inv/4418?u=muhasebe@kartaltekstil[.]example`. The displayed link and the real destination are different. The target is given here with the quoted-printable encoding resolved and the two file lines joined; exactly what the file records byte for byte is in the URL inventory in the Evidence section. | Do not click the link. Warn the recipient `muhasebe@kartaltekstil[.]example` and any other user who may have received the same message not to click the link and not to open the attachment. |
| 10 | High | Body link (line 40) | In that `href` target, the registrable domain is `kyc-dogrulama[.]example`; the `nortvale-invoices[.]example` part is written as a subdomain beneath it. This is a nested / look-alike domain pattern — the familiar-looking name appears, but the domain that actually owns the address is a different one. | Report the message to your organisation's mail gateway as phishing. Decisions on blocking the sender, the domain or the URL at the gateway are yours to apply. |
| 11 | High | Attachment headers (lines 50-52) | There is 1 attachment: `Content-Disposition: attachment; filename="Fatura_NV-2026-4418.pdf.html"`, declared type `text/html; charset=UTF-8`, encoding `base64`. The extension pattern is a double extension (`.pdf.html`) and this is an HTML attachment pattern; the declared type `text/html` contradicts the `.pdf` impression created by the start of the name. | Do not open the attachment. Open a separate decoding / sandbox analysis task for it, in an isolated environment and outside the scope of this review, and request the attachment's SHA-256 digest in writing. |
| 12 | Medium | Body link query string (lines 40-41) | The same URL carries the recipient's own email address in its query string. The file records it as `?u=3Dmuhasebe@kartaltekstil.example`; with the quoted-printable encoding resolved this is `?u=muhasebe@kartaltekstil[.]example`. | — |
| 13 | Info | Attachment body (lines 54-57) | The attachment's base64 body is 4 lines long. The file declares no size header (no `Content-Length`, no `size=`), so there is no declared size. | — |
| 14 | Info | `X-Mailer` (line 23) | The file contains 3 occurrences of the `https?://` pattern in total (the count is in the Evidence section). The third occurrence is the PHPMailer project address inside the `X-Mailer` header; it is not a link offered to the reader by the sender. | — |

CHECK **— what the attachment would do if opened, whether it contains a credential form or a URL, and whether the link is live could not be determined.** The base64 body was not decoded and the file does not state the attachment's purpose anywhere in plain text. Any claim that rests on a file hash — a match against known malware, a link to a campaign — is outside this review, because no hash was produced.

### 3. Authentication results recorded by the receiving gateway — High

These are the receiving gateway's own records, written into the message at the moment of delivery. They were read from the file, not re-tested.

| # | Severity | What was examined (line) | FACT | FIX |
|---|---|---|---|---|
| 15 | High | `Authentication-Results` (line 13) | The recorded result is `spf=fail`, and the SPF check was performed on the envelope domain `smtp.mailfrom=nortvale-invoices[.]example`. | Report the message to the gateway as phishing. |
| 16 | High | `Authentication-Results` (line 14) | The same header records `dkim=none (message not signed) header.d=none`, and the file contains no `DKIM-Signature:` header at all. | — |
| 17 | High | `Authentication-Results` (line 15) | The same header records `dmarc=fail (p=none sp=none dis=none) header.from=nortvale[.]example`. Because the recorded policy is `p=none`, a failing message is still delivered. | Have the gateway's SPF, DKIM and DMARC enforcement behaviour reviewed — in particular that a message with `dmarc=fail` was still delivered — as a separate configuration audit. |
| 18 | High | `Received-SPF` (line 16) | `Received-SPF: fail (... does not designate 45.133.88.214 as permitted sender) client-ip=45.133.88.214` is recorded. | — |
| 19 | Medium | `Authentication-Results` (line 15) and `From` (line 19) | The domain in the DMARC result, `header.from=nortvale[.]example`, differs from the domain in the `From` header, `nortvale-` | — |

| # | Severity | What was examined (line) | FACT | FIX |
|---|---|---|---|---|
| | | | `invoices[.]example` . | |

CHECK **— that the sender domain was genuinely spoofed was not confirmed by this review.** The results above are the gateway's own records from the moment of delivery and were not re-verified here; a live DNS or SPF lookup is a network action and was not performed. Note also the reverse: a recorded `pass` result would only say that authentication succeeded, and would say nothing about intent — a genuine but compromised mailbox passes all three.

### 4. Routing chain and sender identity — Medium

| # | Severity | What was examined (line) | FACT | FIX |
|---|---|---|---|---|
| 20 | Medium | Oldest `Received` hop (line 9) | The oldest hop in the chain is `Received: from localhost (unknown [196.202.14.7])` — a hop whose reverse name was not resolved and was recorded as `unknown` . | — |
| 21 | Medium | Delivering `Received` hop (line 6) | The message reached the recipient via `smtp-out-7.bulkrelay[.]example [45.133.88.214]` , a bulk-relay name that is not declared anywhere as the `From` domain's own infrastructure. | — |
| 22 | Medium | `Message-ID` (line 17) and `From` (line 19) | The `Message-ID` domain is `bulkrelay[.]example` while the `From` domain is `nortvale-invoices[.]example` — they differ. | — |
| 23 | Medium | `From` (line 19) and DMARC result (line 15) | The `From` display name is `"Nortvale Lojistik - Muhasebe"` while the address domain is `nortvale-invoices[.]example` ; the organisation domain appearing in the DMARC record is `nortvale[.]example` . The display name points at one organisation, the address at a hyphenated look-alike of its domain. | — |
| 24 | Medium | `Reply-To` (line 20) | The reply address is `nortvale.finance.dept@mailbox-secure[.]example` — a completely different domain from the `From` domain. A reply would go to that third domain, not to the apparent sender. | Do not reply to the message and do not use the `Reply-To` address for any confirmation. |
| 25 | Info | `X-Originating-IP` (line 24) and oldest hop (line 9) | `X-Originating-IP: [196.202.14.7]` is recorded, the same address as the IP in the oldest hop. | — |
| 26 | Info | `X-Mailer` (line 23) | `X-Mailer: PHPMailer 6.1.6` — the sending library is visible in the headers. | — |

CHECK **— who actually sent the message, what the sender intended, which campaign it belongs to, and whether `196.202.14.7` and `45.133.88.214` are malicious could not be determined.** None of this is written in the file and no reputation lookup was made. A URL and domain reputation lookup for `kyc-dogrulama[.]example` and `mailbox-secure[.]example` would need to be run as a separate task with network access, and its result reviewed before being relied on.

### Further recommended actions

Every item below is a recommendation; applying it is your decision.

- `FIX` — Warn the recipient `muhasebe@kartaltekstil[.]example` , and any other user who may have received the same message, not to click the link and not to open the attachment.
- `FIX` — Report the message to your organisation's mail gateway as phishing. Gateway and blocking decisions (sender, domain, URL) are yours to apply.
- `FIX` — If there is any suspicion that the link was clicked or the attachment was opened, change the credentials that may have been entered, and follow it up at host level with an incident review of the machine concerned.
- `FIX` — Have a URL and domain reputation lookup for `kyc-dogrulama[.]example` and `mailbox-secure[.]example` carried out as a separate, network-enabled task; treat its result as unconfirmed until it has been reviewed and approved.
- `FIX` — Have the gateway's SPF, DKIM and DMARC enforcement behaviour reviewed — for instance that a message with `dmarc=fail` was still delivered.
- `FIX` — Have your mail gateway logs examined to establish whether the message reached other mailboxes and whether anyone clicked.
- `FIX` — Open a separate decoding / sandbox analysis task for the attachment, in an isolated environment and outside the scope of this review, and request the attachment's SHA-256 digest in writing.
- `FIX` — Confirm the bank / payment-account change through a channel you already trusted beforehand, never through the message itself.

## Evidence

The lines below are quoted exactly as the email file records them, including the raw web addresses. They are reproduced verbatim so the counts and findings can be reproduced; do not open them.

### File and counts (search in counting mode)

File: `samples/ornek-phishing.eml`

- `59` — total lines; counting-mode search, pattern `^` → 59
- `3` — URL occurrences; counting-mode search, pattern `https?://` → 3 (lines 23, 40, 41)
- `1` — attachments; counting-mode search, pattern `(filename=|Content-Disposition: attachment)` → 1 matching line (line 52; the `name=` parameter on line 50 belongs to the same attachment)
- `3` — `Received:` headers; counting-mode search, pattern `^Received:` → 3 (lines 3, 6, 9)
- `3` — MIME boundary lines; counting-mode search, pattern `^------=_Part_8841_1761545673` → 3 (lines 29, 49, 59)
- Structure: the header block ends at line 27, the first blank line is line 28, the body starts at line 29. `boundary="----=_Part_8841_1761545673"` (line 27). Part 1: lines 29-47 ( `text/html` body). Part 2: lines 49-57 (attachment). Closing boundary: line 59.
- Search for text aimed at an automated agent: the patterns `ignore|disregard|previous instruction|mark (this|it) as safe|forward the headers|talimat|güvenli işaretle|yok say` produced no match in the file (0 matches).

### Six-item checklist

| # | Check | Header / line examined | Reason | Result |
|---|---|---|---|---|
| 1 | Received chain | lines 9, 6, 17, 23, 24 | Oldest hop `from localhost (unknown [196.202.14.7])` ; delivering hop is the bulk-relay name `smtp-out-7.bulkrelay.example` ; `Message-ID` domain `bulkrelay.example` differs from the `From` domain; `X-Mailer: PHPMailer 6.1.6` is visible | Indicator found |

| # | Check | Header / line examined | Reason | Result |
|---|---|---|---|---|
| 2 | SPF (as recorded) | lines 13, 16 | `spf=fail`; the check was run on the envelope domain `smtp.mailfrom=nortvale-invoices.example`, and `Received-SPF` is also `fail` | Indicator found |
| 3 | DKIM (as recorded) | line 14 | `dkim=none (message not signed) header.d=none`; no `DKIM-Signature:` header in the file | Indicator found |
| 4 | DMARC (as recorded) | lines 15, 19 | `dmarc=fail (p=none sp=none dis=none)`; `header.from=nortvale.example` while the `From:` domain is `nortvale-invoices.example` — different | Indicator found |
| 5 | From / Reply-To / Return-Path / display name | lines 1, 19, 20, 21 | `Reply-To` domain `mailbox-secure.example` differs from the `From` domain `nortvale-invoices.example`; the display name is "Nortvale Lojistik - Muhasebe" while the domain is a hyphenated, extra-word look-alike of the organisation domain (`nortvale.example`) | Indicator found |
| 6 | URL and attachment inventory | lines 40-42, 50-52 | The `href` target differs from the displayed link text; the registrable domain is `kyc-dogrulama.example` with `nortvale-invoices.example` nested beneath it; the recipient's address is in the query string; the attachment `Fatura_NV-2026-4418.pdf.html` is a double-extension HTML attachment | Indicator found |

Total: 6 with an indicator + 0 clean + 0 without evidence = 6.

A clean result would mean only that no indicator was seen in this export; it would not prove the message legitimate. There is no clean row in this review.

### URL inventory (3 occurrences in total — none visited)

The "As written in the file" column reproduces the file's lines exactly, including the quoted-printable `=3D` and the soft line-break marker `=` at the end of a line. The "Decoded and joined" column is the readable form of the same value, obtained by converting `=3D` to `=` and joining the soft line breaks; that column is the result of decoding — the string does not appear in the file as one piece.

| # | Line | As written in the file (byte for byte) | Decoded and joined | Text shown to the reader |
|---|---|---|---|---|
| 1 | 40-41 | line 40: `<a href=3D"http://nortvale-invoices.example.kyc-dogrulama.example/inv/4418=` · line 41: `?u=3Dmuhasebe@kartaltekstil.example">https://portal.nortvale.example/fatu=` | `http://nortvale-invoices.example.kyc-dogrulama.example/inv/4418?u=muhasebe@kartaltekstil.example` | `https://portal.nortval` |
| 2 | 41-42 | end of line 41: `https://portal.nortvale.example/fatu=` · line 42: `ra/4418</a></p>` | `https://portal.nortvale.example/fatura/4418` | — (this is the displayed text |
| 3 | 23 | `X-Mailer: PHPMailer 6.1.6 (https://github.com/PHPMailer/PHPMailer)` | `https://github.com/PHPMailer/PHPMailer` (no quoted-printable, no line split) | — |

No link-shortening service, bare-IP host, QR code or image was seen in the file. None of these URLs was resolved, opened or previewed.

### Attachment inventory (1 in total — not executed, not decoded)

| # | Lines | File name | Declared Content-Type | Encoding | Size | Extension pattern |
|---|---|---|---|---|---|---|
| 1 | 50-57 | `Fatura_NV-2026-4418.pdf.html` | `text/html; charset=UTF-8` | `base64` | No size declared in the file; the base64 body is 4 lines (54-57) | Double extension `.pdf.html`; HTML attachment; the name suggests `.pdf` while the declared type is `text/html` |

### Indicator list (with source lines; none of these has been confirmed malicious)

- `samples/ornek-phishing.eml:1` — `Return-Path: <billing@nortvale-invoices.example>`
- `samples/ornek-phishing.eml:19` — `From: "Nortvale Lojistik - Muhasebe" <billing@nortvale-invoices.example>`
- `samples/ornek-phishing.eml:20` — `Reply-To: "Nortvale Muhasebe" <nortvale.finance.dept@mailbox-secure.example>`
- `samples/ornek-phishing.eml:6` — sending IP `45.133.88.214`, host `smtp-out-7.bulkrelay.example`
- `samples/ornek-phishing.eml:9` / `:24` — originating IP `196.202.14.7`
- `samples/ornek-phishing.eml:17` — `Message-ID: <20261027061433.9c118a2e0f@bulkrelay.example>`
- `samples/ornek-phishing.eml:40` — domain `kyc-dogrulama.example` and the URL (row 1 of the URL inventory above)
- `samples/ornek-phishing.eml:52` — attachment name `Fatura_NV-2026-4418.pdf.html`

### Relevant header lines (verbatim)

- `samples/ornek-phishing.eml:9` — `Received: from localhost (unknown [196.202.14.7])`
- `samples/ornek-phishing.eml:13` — `spf=fail (sender IP is 45.133.88.214) smtp.mailfrom=nortvale-invoices.example;`
- `samples/ornek-phishing.eml:14` — `dkim=none (message not signed) header.d=none;`
- `samples/ornek-phishing.eml:15` — `dmarc=fail (p=none sp=none dis=none) header.from=nortvale.example`
- `samples/ornek-phishing.eml:16` — `Received-SPF: fail (nortvale.example: domain of nortvale-invoices.example does not designate 45.133.88.214 as permitted sender) client-ip=45.133.88.214;`
- `samples/ornek-phishing.eml:22` — `Subject: =?UTF-8?B?QUNJTDogw5ZkZW1lIGhlc2FiIGRlxJ9pxZ9pa2xpxJ9pIC0gRmF0dXJhIE5WLTIwMjYtNDQxOA==?=`
- `samples/ornek-phishing.eml:23` — `X-Mailer: PHPMailer 6.1.6 (https://github.com/PHPMailer/PHPMailer)`
- `samples/ornek-phishing.eml:35` — `<p>Banka hesab=C4=B1m=C4=B1z de=C4=9Fi=C5=9Fmi=C5=9Ftir. A=C3=A7=C4=B1k =`
- `samples/ornek-phishing.eml:52` — `Content-Disposition: attachment; filename="Fatura_NV-2026-4418.pdf.html"`

## Verification

Every FACT in this document rests on a line quoted from the email file, and every number comes either from a counting-mode search or from the itemised counts in the Evidence section above; no number was estimated. The counts are consistent: 6 checks with an indicator + 0 clean + 0 without evidence = 6; 3 URL occurrences across the three inventory rows (lines 23, 40, 41); 1 attachment (line 52, with the `name=` parameter on line 50 belonging to the same attachment); the file has 59 lines.

Rather than a flat "this is phishing" verdict, the indicators actually observed are stated as facts, and the sender's intent, the real sender's identity, whether the link is live and what the attachment would do are stated as items that could not be determined and are marked CHECK. Reputation lookups, file hashing and dynamic analysis were outside this review, and the severity words above order the recorded indicators rather than rule on intent.

An independent second review re-derived the six-item checklist, the URL and attachment counts and every fact from the source file by its own method before delivery, and the numbers matched.

This document is a synthetic portfolio sample. It demonstrates the review method on a constructed email file and does not describe a real engagement, a real organisation or a real incident.